Yellow RAT Lab

1. Kịch bản

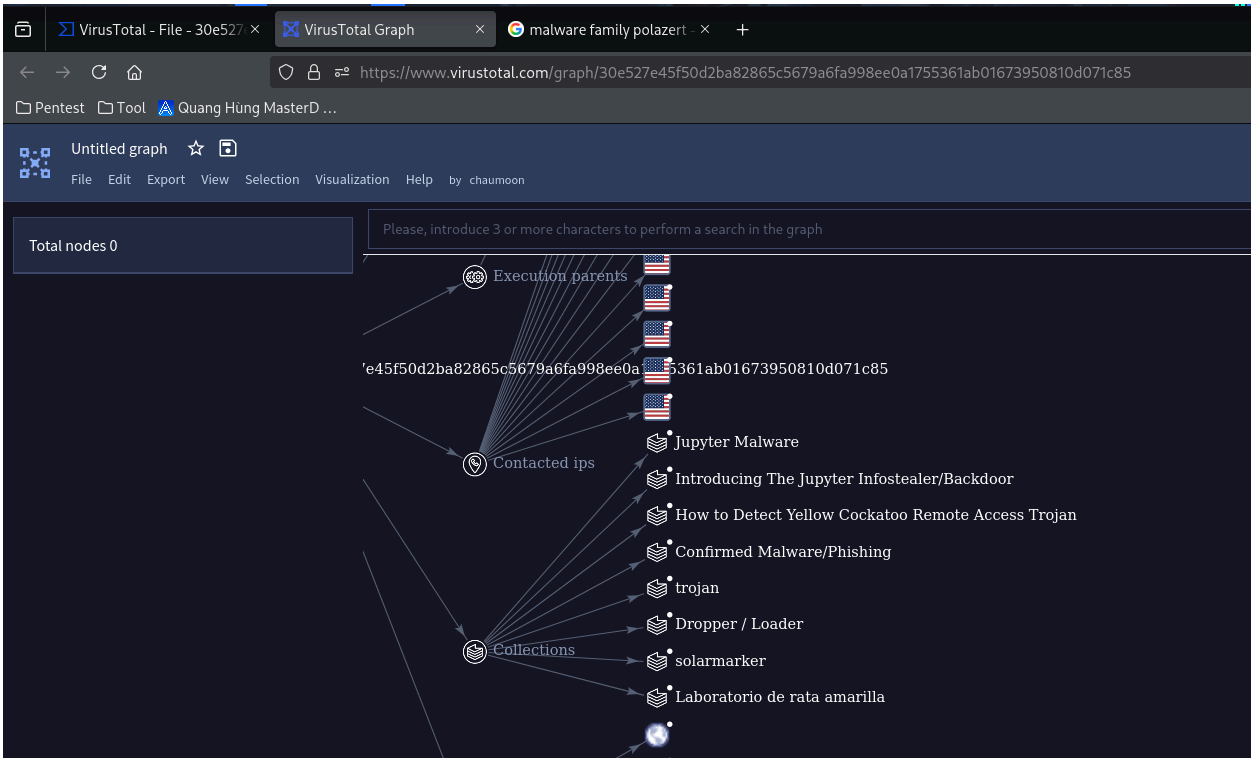
- Lưu lượng mạng bất thường xuất hiện từ nhiều workstation. Truy vấn tìm kiếm của nhân viên bị redirected đến web lạ. Hãy điều tra sự cố và thu thập thông tin

2. Write up

- Hash: 30E527E45F50D2BA82865C5679A6FA998EE0A1755361AB01673950810D071C85

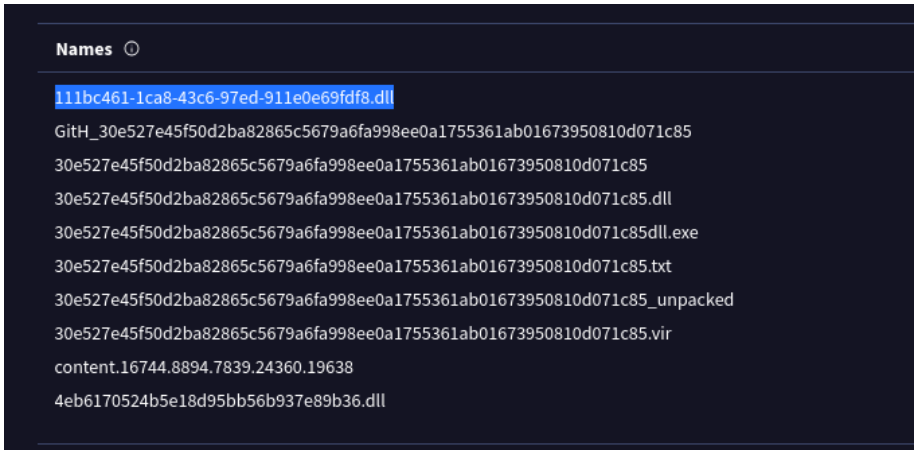
1. Understanding the adversary helps defend against attacks. What is the name of the malware family that causes abnormal network traffic?

- Yêu cầu: đối với malware hãy tìm hiểu họ của nó trước để biết hành vi của nó
- As: Yellow Cockatoo RAT
- Thông tin này cho biết các danh mục/bộ hồ sơ được tạo cho dòng mã độc này



2. As part of our incident response, knowing common filenames the malware uses can help scan other workstations for potential infection. What is the common filename associated with the malware discovered on our workstations?

- Yêu cầu: tìm các filename malware sử dụng để quét các máy trạm khác tìm kiếm lây nhiễm
  - Thường dùng IOC khó thay đổi hơn
    - File .dat trong AppData
    - IP cùng dải hoặc cùng nhà cung cấp dịch vụ (ASN) với C2 server
- As: 111bc461-1ca8-43c6-97ed-911e0e69fdf8.dll
- Mục Name trên Virustotal chứa các filename từng được phát hiện của malware



3. Determining the compilation timestamp of malware can reveal insights into its development and deployment timeline. What is the compilation timestamp of the malware that infected our network?

- Yêu cầu: tìm thời gian biên dịch → timeline phát triển và triển khai
- As: 2020-09-24 18:26

```
Creation Time
2020-09-24 18:26:47 UTC
First Seen In The Wild
2021-01-18 20:15:04 UTC
First Submission
2020-10-15 02:47:37 UTC
```

```
Last Submission
2025-07-05 19:05:08 UTC
Last Analysis
2026-04-18 16:06:01 UTC
```

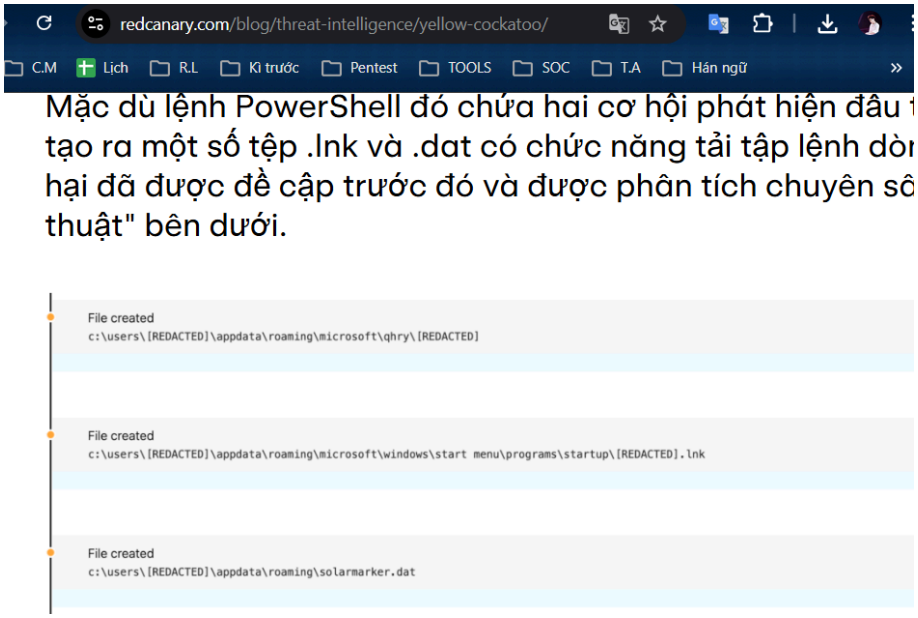
- Thông tin thời gian cho thấy từ thời điểm tạo đến lúc phát hiện là gần 3 tháng. Đây có thể là thời gian tinh chỉnh malware trước khi đưa ra triển khai quy mô lớn

4. Understanding when the broader cybersecurity community first identified the malware could help determine how long the malware might have been in the environment before detection. When was the malware first submitted to VirusTotal?

- Yêu cầu: thời gian first submit là thời điểm cộng đồng an ninh mạng phát hiện malware (trước đó nó chưa bị phát hiện)
- As: 2020-10-15 02:47

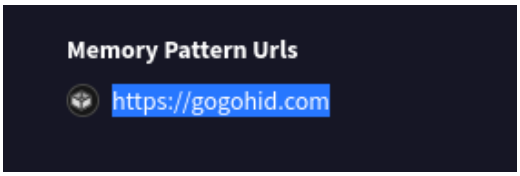
5. To completely eradicate the threat from Industries' systems, we need to identify all components dropped by the malware. What is the name of the **.dat** file that the malware dropped in the **AppData** folder?

- Yêu cầu: để hoàn toàn loại bỏ đe doạn → cần xác định tất cả dropper malware đã thả vào
- As: solarmarker.dat
- Tìm kiếm thông tin về mối đe dọa này trên mạng



- DAT (data): file chứa dữ liệu tổng quát
- Tại sao hacker lọi dụng thư mục AppData
  - Quyền: đọc/ghi và thực thi với quyền user
  - Nơi các app hợp pháp lưu data → dễ giả mạo
  - Persistence: AppData\Roaming không bị xóa khi dọn dẹp, reg trỏ vào để run cũng ít bị AV tool nghi ngờ
    - Nếu chưa kịp lây sang máy khác hay leo thang để chuyển sang thư mục hệ thống thì khi xóa user, malware cũng bốc hơi theo

6. It is crucial to identify the C2 servers with which the malware communicates to block its communication and prevent further data exfiltration. What is the C2 server that the malware is communicating with?

- Yêu cầu: xác định C2 server để chặn giao tiếp và ngăn đánh cắp data
- As: https://gogohid.com
- Memory Pattern URLs: chứa URL xuất hiện trong RAM (chưa chắc là hacker đã kết nối tới)
  - Muốn xác nhận:
    - Truy vấn HTTP/S và DNS log để kiểm tra

- Sysmon Event ID 3 (Network Conn): xác định chính xác tiến trình khởi tạo kết nối mạng